
Travaux pratiques 04

Ce TP sera évalué par un rapport (voir Section 4) que vous devrez envoyer à votre enseignant de TP.

1 Configuration

Bash et openssl. Si vous n’avez pas de terminal avec bash à disposition (avec openssl installé), vous avez accès à un terminal en ligne :

<https://tiny.cc/Securite>

Le shell de base n’est pas bash, mais vous pouvez utiliser `/bin/bash`. Le programme `openssl`, déjà utilisé lors du TP 3, est disponible.

Téléchargement. On abstrait l’utilisation d’openssl avec un script qui automatise les appels. Pour l’installer :

```
wget http://tiny.cc/PingAuthentifie
source ping_securise.sh
```

Initialisation. Avant d’aller plus loin, vous devez créer une paire clef publique/clef privée avec :

```
clefs_rsa
```

2 Phase d’échange des clefs

Communication. Toutes les communications se font sur un serveur Discord. Les commandes que vous utilisez dans le terminal affichent (sur une seule ligne) des messages à copier-coller dans Discord de la forme :

```
alice -> bob : IekZGSM6yo8BBQJNYkg171ax8DFU0FVMJ05L8B2vLDiCYnuVA
i56GUSYQgF7xIkgGct4I5ypDBj6ZnZh5veDJrwMTYMMN3DWdkHkputvN6RqaWk40
JA1osSkA1tPVy+gT781VfGRs1C3kpvT45ene2Nw+21nreXp6IUtq3UBAZSG5xGH+
FKcJo/WC40X2GPc0ela+HTOKvuThxaQrI3psjKXzgeAM+/29aZ50osK1hnIuyFq7
a3jgMvONK48FUBJ1HapJtanluiv4028fy5fMjozdUrKUG2xY1Rfr1BshdT7/Y/7j
bpanbd6w2aCVso8sEsicBAW4zfkXdlJE9ADAA==
```

Pour utiliser les informations envoyées sur Discord, il suffit de copier-coller de Discord dans votre terminal.

Échange des clefs. Cette partie n’est pas sécurisée : en général, soit on doit faire confiance à des entreprises (cherchez les certificats dans votre navigateur, par exemple), soit rencontrer physiquement des personnes (avec GPG) pour s’assurer de leur identité. Plutôt que de mettre en place une solution bancaire, on vous fait confiance pour choisir un pseudonyme différent de celui des autres pour publier les messages.

Publication : Pour publier votre clef publique, utilisez :

`publie_clef_publicue alice`

et mettez le résultat sur discord.

Enregistrement : Pour enregistrer une clef publique qui a été publiée sur Discord, il vous suffit de copier-coller la ligne dans votre terminal :

```
ajoute_clef_publicue prof:MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEA+5spwSru/P5j0ORrQkmr52xH/7lzg7FtsjW3wCz2bE7khRt5XSn2ve28avyJ4gS/l/mp2vJaVzYfHQ5i37hIUgTOl27+ekVqtaMcbIM6KJSNbdedtaZbZRCV3EOpPkgHwGnYwsa2br3zEBHJT9b51axFDuc0kOHzsTzZOubaqO20zkewYsUApLfcyE8sKWfxoumciyKpZnxZPwRk/15MezboEum4Exl0wUlrD/V6PjJlrIfBPKhby+5mFUSCTNr37IHGttBoanG4cEi5lDrohQ0EZry1O+jYkCftsDkiDcD3VVmptwWSXagTTim8JeDthLsVbQtEObPnxAmVuBGd6wIDAQAB
```

3 Protocole de ping authentifié

Le protocole **ping** sert à savoir si une machine à une adresse internet donnée est connectée à Internet et est prête à répondre à des requêtes. Mais rien ne permet de savoir si la machine qui était à cette adresse a été remplacée par une autre, en qui on ne peut pas avoir confiance. Le protocole de **ping authentifié** permet de garantir que la machine qui répond est bien la machine qui avait été déployée si on se fie à ses clefs publiques et privées. Le protocole entre deux machines A et B , souvent appelées *alice* et *bob*, est décrit par les messages suivants :

$$\begin{array}{ll} 1.A & B \rightarrow \{A.Na\}Kb : \\ 2.B & A \rightarrow \{Na.Nb\}Ka : \\ 3.A & B \rightarrow \{Nb\}Kb : \end{array}$$

où :

- Na et Nb sont des *nonces*, c'est-à-dire des nombres aléatoires qui ont été créés pour cette *session*, c'est-à-dire pour un échange spécifique de messages entre deux personnes ;
- Kb est la clef publique de B , et Ka est la clef publique de A .

Les propriétés de sécurité assurées par ce protocole sont :

- à la réception du deuxième message, A est sûre d'avoir communiqué avec B ;
- à la réception du troisième message, B est sûr d'avoir communiqué avec A ;
- les 2 nonces Na et Nb ne sont connus que de A et B , et peuvent être utilisés pour créer une clef symétrique pour chiffrer les communications entre A et B ¹

Reste du TP. Pour le reste du TP (et pour le rapport), vous devez vous mettre par groupes de 3 ou 4, et utiliser ce protocole pour faire des sessions :

- au sein d'un groupe ;
- entre 2 groupes ;
- avec l'enseignant.

Pour ne pas encombrer le forum, vous pouvez envoyer ces messages en privé (mais ce n'est pas obligatoire).

¹Depuis, on utilise plutôt le protocole de Diffie-Hellman pour cela, car il peut être fait sans aller-retour.

4 Rapport noté

Le rapport à écrire est en 2 parties, idéalement d'une ou deux pages, et est à renvoyer par mail à votre enseignant de TP. Le but est de faire une analyse de sécurité méticuleuse d'un programme pour s'assurer qu'il n'a pas de vulnérabilités exploitables².

Première partie : preuve de correction d'un protocole. Une manière de prouver la sécurité d'un protocole cryptographique est de raisonner sur les connaissances des différents agents (participants ou extérieurs) aux différents étapes d'une session du protocole. Ces étapes sont, pour chaque message :

avant l'envoi : c'est l'étape où les nonces sont créés et "appris" par leur créateur ;

après l'envoi/avant la réception : c'est l'étape où un non-participant peut apprendre le message ;

après la réception : c'est l'étape où le destinataire apprend le message et en extrait les informations.

Il y a une étape supplémentaire d'initialisation, à laquelle tout le monde apprend les identités et les clefs publiques de tout le monde, et sa propre clef privée.

Faites un tableau avec une ligne par étape (10 en tout), et une colonne pour A , B , et un observateur extérieur. Mettez dans chaque case les connaissances acquises à cette étape (les agents n'oublient rien.)

En vous appuyant sur ce tableau, indiquez, juste avant la réception du second message par A , quelles sont les personnes qui ont pu construire ce message.

De même, toujours en raisonnant sur le tableau, indiquez quelles sont les personnes qui ont pu construire le message 3 reçu par B .

Expliquez comment comment on peut en conclure que ce protocole implémente bien un ping sécurisé mutuel entre A et B .

Seconde partie : log et analyse de traces. En copiant quelques (2 ou 3) traces d'exécution, montrez quelles exécutions ont eu lieu, et faites le lien avec les étapes du protocole de ping sécurisé.

Si vous pensez qu'il y a un problème, montrez lequel en copiant une trace d'exécution et essayez soit d'expliquer l'erreur, soit d'expliquer pourquoi il n'y a en fait pas eu de problème.

²L'analyse de la première partie est basée sur celle du ping sécurisé formalisée par un directeur de la recherche de Microsoft et l'un des créateurs de TensorFlow